Test Project Selection

Task C

William A. Davis
CS 690 Graduate Research Project, Fall 2026
Advisor: Dr. Omar Ochoa
October 06, 2026

Selected Projects

I selected four open-source projects, one from each major package ecosystem. Each is pinned to a release tag so its SBOM can be regenerated exactly with scripts/generate_sboms.sh. The SBOMs are stored in data/sboms, and a table of every component's depth for each project is stored in data/tables (CSV files that open in Excel).

Project	Release	Ecosystem	Components	Dependency links	Direct	Max depth
OWASP Juice Shop	v20.2.0	npm	689	1,063	63	7
OWASP PyGoat	v2.0.1	Python	33	41	16	3
OWASP WebGoat	v2026.4	Maven	191	380	37	8
Gitea	v1.21.0	Go	231	733	110	3

The dependency link counts include the links from the application to its direct dependencies.

OWASP Juice Shop is a large JavaScript application with a deep dependency tree, and it intentionally pins old, vulnerable packages such as jsonwebtoken 0.4.0 and sanitize-html 1.4.2. OWASP PyGoat is a small Django application with old pins, including Django 4.1.7, PyYAML 5.1 and cryptography 39.0.1; it is small enough that every ranking can be checked by hand. OWASP WebGoat has the deepest tree of the four, combining a current Spring Boot stack with deliberately old libraries such as jjwt 0.9.1. Gitea is real production software rather than a training application, and its 2023 release carries genuine vulnerabilities that were fixed later, such as the one in golang.org/x/crypto v0.14.0.

Selection Criteria

Each project had to have public source code and a reproducible build input: a lockfile, pinned requirements, a Maven POM or a go.mod file. The four had to span different ecosystems, because dependency structure varies widely between them. Go graphs are shallow and npm and Maven graphs are deep, so using all of them tests whether the depth factor behaves sensibly across ecosystems. Each project had to contain known vulnerabilities, since rankings cannot be compared with the baseline otherwise. Finally, the set mixes training applications with production software. The three OWASP projects are intentionally vulnerable, which guarantees enough vulnerable components to rank but

could overstate how often contextual scoring changes the order. Gitea is included as a real-world check on that bias.

Notes on Individual Projects

Juice Shop does not commit a lockfile, so one was generated on October 11, 2026. Exact pins in its package.json keep the result close to the release, but any version ranges resolve to the versions current on that date, so the evaluation should record it.

PyGoat's requirements.txt is a complete freeze of every installed package, so it does not say which packages the application asked for directly. Direct dependencies were therefore inferred as the listed packages that no other installed package requires, together with the packages its source code imports directly (Django, requests, PyJWT, PyYAML, argon2-cffi, Pillow and django-heroku). The Python SBOM generator also records optional extras as if they were required dependencies, so the ten links that pip itself does not consider required were removed. The validation report describes this in detail.

WebGoat's release tag builds with the version label 2026.4-SNAPSHOT in its POM. This is cosmetic, because the dependency versions come from the tagged POM. Gitea's SBOM covers the Go modules linked into the server binary; its frontend npm packages and Python tooling are outside the scope of this SBOM.

Possible Fifth Project

If time allows during evaluation, a second real-world project could be added. A Java service from the Log4Shell era, using log4j-core 2.14.x, would provide a well-known KEV example for the explanations.